Phishing leading to data theft from the Finance share

Incident report, case ALDERLINE-2026-0310

Case	ALDERLINE-2026-0310
Organisation	Alderline Payments
Date of activity	10 March 2026
Severity	Critical
Prepared by	Elay Adar
Report date	15 July 2026
Status	Escalated to Tier 2

1. Executive summary

On 10 March 2026, 08:12 AM, one of the users got mail that contained file which masqueraded as a legitimate Word file, the malicious file ran scripted commands that created new scheduled task, disabled detection of anti spyware software's, ran reconnaissance commands and eventually harvest user credentials with domain admin permissions.

With this permissions the attacker managed to to access the main file server and read sensitive large volume finance data. Based on the attack pattern and what the attacker has done so far, is it most likely the finance data has been left the organization but it not yet been confirmed.

In addition there was tow failed attempts:

- Connect from the compromised workstation to the main database server.
- Delete backups on the backup server.

The incident is rated Critical: the attacker has compromised user with domain admin permissions, and there is a strong suspicion of finance data that left the organization to unrecognized destination.

2. Scope

- Hosts: WKS-YCOHEN (10.10.2.45) - patient zero.
- Accounts: y.cohen, ALDERLINE\admin_dana, svc_backup.
- Associated systems in the attack: DC01, FS01 Finance$ share.
- Failed to reach: DB01, BKP01.

Considered as noise: 2, 6, 9, 14, 17 and 20. All this alerts match the norm and no connection could be established between them and the attack.

Considered as unrelated incident: 4 and 12. The norm contains no provisions prohibiting or authorizing specific methods of USB usage; however, given that company data is involved, we should address this matter separately.

3. Timeline

Time (UTC)	Event
08:12	Email with a .docm attachment delivered to y.cohen (ticket 8)
08:47	powershell.exe started by WINWORD.EXE on WKS-YCOHEN (ticket 5)
09:15	New scheduled task created on WKS-YCOHEN (ticket 16)
09:40	DisableAntiSpyware registry value changed on WKS-YCOHEN (ticket 13)
10:05	whoami /all and net group run on WKS-YCOHEN (ticket 19)
10:30	rundll32.exe accessed lsass.exe memory on WKS-YCOHEN (ticket 10)
11:00	RDP logon to DC01 as admin_dana (ticket 1)
11:20	File reads on \\FS01\Finance$ by admin_dana (ticket 15)
12:00	High-rate DNS queries from WKS-YCOHEN (ticket 18)
12:20	SMB connection from WKS-YCOHEN to DB01 blocked (ticket 7)
12:45	Outbound transfer of 1.4 GB from WKS-YCOHEN (ticket 3)
13:10	vssadmin delete shadows run as svc_backup (ticket 11)

4. Findings

Alert	Evidence and indicators	Deviation from baseline
Ticket 8 Email with a .docm attachment delivered to y.cohen	Sender: billing-support@invoice-verify-secure[.]com Recipient: y.cohen@alderline.co.il Attachment: Invoice_48213.docm	File that has macro attachment that sent from unknown email
Ticket 5 powershell.exe started by WINWORD.EXE on WKS-YCOHEN	Host: WKS-YCOHEN Parent Process: WINWORD.EXE Child Process: powershell.exe -nop -w hidden -enc [base64 payload truncated]	Word file doesn't supposed to create Powershell process. The powershell command is encoded(-enc flag) contrary to the norm and also use hidden mode to keep unwanted attention.

Alert	Evidence and indicators	Deviation from baseline
`Ticket 16` New scheduled task created on WKS-YCOHEN	Host: WKS-YCOHEN Task Name: \Microsoft\Windows\WinUpdateCheck Action: C:\Users\ycohen\AppData\Local\Temp\svhost.exe Trigger: At logon	Violate the "no scheduled tasks created by the user" rule. the scheduled task try to use legitimate Windows process name to disguise it's action as legitimate.
`Ticket 13` DisableAntiSpyware registry value changed on WKS-YCOHEN	Host: WKS-YCOHEN Registry: HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\DisableAntiSpyware = 1 Actor Process: powershell.exe (PID 4820)	Violate the "no registry changes that turn off protection" rule.
`Ticket 19` whoami /all and net group run on WKS-YCOHEN	Host: WKS-YCOHEN Process: cmd.exe Command Line: whoami /all && net group "Domain Admins" /domain	Regular user does not supposed to ran reconnaissance commands.
`Ticket 10` rundll32.exe accessed lsass.exe memory on WKS-YCOHEN	Host: WKS-YCOHEN Process: rundll32.exe accessing lsass.exe (PID 692) Access Pattern: MiniDump Detection Rule ID: EDR-0891	Exploitation of legitimate Windows process(LOTL) to harvest credentials form memory process(lsass.exe). Later there is use in admin_dana's stolen credentials.
`Ticket 1` RDP logon to DC01 as admin_dana	EventID: 4624 Account: ALDERLINE\admin_dana Src IP: 10.10.2.45 Workstation Name: WKS-YCOHEN	WKS-YCOHEN is not the standard workstation from which admin_dana connects.

Alert	Evidence and indicators	Deviation from baseline
`Ticket 15` File reads on \\FS01\Finance$ by admin_dana	EventID: 4663 Account: admin_dana Object: \\FS01\Finance$* Access: ReadData Session Source: DC01 Count: 412 files / 6 minutes	Human cannot read 412 files in 6 minutes(non-human behavior) which indicates to automatics scripts for collecting data. The connection to the shared folder was created from the infected workstation WKS-YCOHEN.
`Ticket 18` High-rate DNS queries from WKS-YCOHEN	Src: 10.10.2.45 Query: 8f2ac91e0b[.]update-cdn-relay.net (+339 similar) Rate: 340 queries/min Subdomain Entropy: high	No user should requests 340 queries per minute(also non-human behavior). only Subdomain changes which indicate to DNS tunneling and all of this happened form compromised host WKS-YCOHEN.
`Ticket 7` SMB connection from WKS-YCOHEN to DB01 blocked	Action: DENY Src: 10.10.2.45 Dst: 10.10.1.30 (DB01) Port: 445/TCP Rule ID: FW-SEG-114	Violate the "no traffic to DB01" rule by Employee workstations. The attempt is from compromised host WKS-YCOHEN.
`Ticket 3` Outbound transfer of 1.4 GB from WKS-YCOHEN	Src: 10.10.2.45 Dst: filebin-share[.]net Method: POST Bytes Out: 1.4 GB Category: Uncategorized Cloud Storage Action: Allowed	Large transfer from compromised host to unrecognized cloud storage domain with allow verdict.

Alert	Evidence and indicators	Deviation from baseline
`Ticket 11` vssadmin delete shadows run as svc_backup	EventID: 4688 Account: svc_backup Command Line: vssadmin.exe delete shadows /all /quiet Src IP: 10.10.2.45 Result: Access Denied	There is no legitimate use or any advance notice for deletion of backups. The command use quiet mode to avoid attention.

5. MITRE ATT&CK mapping

Alert	Tactic	Technique	Justification
`Ticket 8` Email with a .docm attachment delivered to y.cohen	Initial Access (TA0001)	T1566.001 Phishing: Spearphishing Attachment	Malicious file send by email to run automated scripts on the victim's workstation.
`Ticket 5` powershell.exe started by WINWORD.EXE on WKS-YCOHEN	Execution (TA0002)	T1204.002 User Execution: Malicious File T1059.001 Command and Scripting Interpreter: PowerShell	The malicious file create child process Powershell to execute commands on the victim's workstation.
`Ticket 16` New scheduled task created on WKS-YCOHEN	Stealth (TA0005) Persistence (TA0003)	T1053.005 Scheduled Task/Job: Scheduled Task T1036.005 Masquerading: Match Legitimate Resource Name or Location	The scheduled task was called by legitimate Windows software with missing 'c' letter: svchost.exe
`Ticket 13` DisableAntiSpyware registry value changed on WKS-YCOHEN	Defense Impairment (TA0112)	T1685 Disable or Modify Tools T1112 Modify Registry	The attacker attempts to modify the registry value to prevent the defense mechanisms from detecting the malicious activity.
`Ticket 19` whoami /all and net group run on WKS-YCOHEN	Discovery (TA0007)	T1033 System Owner/User Discovery T1069.002 Permission Groups Discovery: Domain Groups	The attacker gathers information about the user and determine if they belong to security groups or possess special privileges and collects data on users in privileged groups to strengthen his foothold within the organization.

Alert	Tactic	Technique	Justification
`Ticket 10` rundll32.exe accessed lsass.exe memory on WKS-YCOHEN	Credential Access (TA0006) Stealth (TA0005)	T1003.001 OS Credential Dumping: LSASS Memory T1218.011 System Binary Proxy Execution: Rundll32	Use of legitimate windows as proxy software to steal credentials from memory.
`Ticket 1` RDP logon to DC01 as admin_dana	Lateral Movement (TA0008) Privilege Escalation (TA0004)	T1021.001 Remote Services: Remote Desktop Protocol T1078.002 Valid Accounts: Domain Accounts	Spreading from compromised workstation into another asset with Privilage user.
`Ticket 15` File reads on \\FS01\Finance$ by admin_dana	Collection (TA0009)	T1039 Data from Network Shared Drive	Reads from shared folder by EventID 4663
`Ticket 18` High-rate DNS queries from WKS-YCOHEN	Command and Control (TA0011)	T1071.004 Application Layer Protocol: DNS T1572 Protocol Tunneling	High frequency, where the subdomain changes with each request and appears random - strong indicate for DNS feature abuse.
`Ticket 7` SMB connection from WKS-YCOHEN to DB01 blocked	Lateral Movement (TA0008)	T1021.002 Remote Services: SMB/Windows Admin Shares	Attempt to spread into DB01
`Ticket 3` Outbound transfer of 1.4 GB from WKS-YCOHEN	Exfiltration (TA0010)	T1567.002 Exfiltration Over Web Service: Exfiltration to Cloud Storage	1.4 GB uploaded over HTTPS to unrecognized domain filebin-share.net
`Ticket 11` vssadmin delete shadows run as svc_backup	Impact (TA0040) Stealth (TA0005)	T1490 Inhibit System Recovery T1078 Valid Accounts	Failed attempt to delete backup with credentials of svc_backup.

6. Indicators of compromise

Sender domain: billing-support@invoice-verify-secure.com

Attachment: Invoice_48213.docm

Command and control domain: update-cdn-relay[.]net

Exfiltration domain: filebin-share.[.]net

File path: C:\Users\ycohen\AppData\Local\Temp\svhost.exe

Scheduled task name: \Microsoft\Windows\WinUpdateCheck

Registry path: HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\DisableAntiSpyware = 1

Commands:

- powershell.exe -nop -w hidden -enc, with WINWORD.EXE as parent
- whoami /all && net group "Domain Admins" /domain
- vssadmin.exe delete shadows /all /quiet

Process access: rundll32.exe opening lsass.exe with MiniDump access

7. Actions taken

- Correlated 20 incoming alerts, filtering out 6 routine noise events and 2 unrelated DLP events to isolate the 12 attack-related events.
- Confirmed with firewall and Windows Security logs that SMB access to DB01 and shadow copy deletion on BKP01 were blocked.
- Initiated an escalation of Case ALDERLINE-2026-0310 to Tier 2 with Critical severity.
- Issued an urgent request via EDR for network isolation of WKS-YCOHEN (10.10.2.45).
- Requested temporary account suspension and credential revocation for y.cohen, admin_dana, and svc_backup.
- Submitted block requests on Email Gateway, Proxy, and DNS for malicious infrastructure: invoice-verify-secure[.]com, update-cdn-relay[.]net, and filebin-share[.]net.

8. Not checked

Memory and disk forensics on WKS-YCOHEN, including deeper analysis of svhost.exe and the decoded PowerShell command.

Verification of whether other employees received the same or a similar phishing email across the organization.

Comprehensive review of potential persistence mechanisms or secondary activities left by the attacker on DC01 beyond the observed file reads.

Detailed content analysis of the 1.4 GB uploaded to filebin-share[.]net to identify exact data exfiltration items.

9. Open questions

What specific actions and payloads were executed by the encoded PowerShell command?
What were the exact functions and behavior of the svhost.exe binary upon execution?
Beyond admin_dana and svc_sql, were any additional credentials dumped from lsass.exe?
What specific categories or files comprised the 1.4 GB data transfer and the data encoded within the DNS tunneling queries?

10. Recommendations

Immediate Actions:

- Verify full network isolation of WKS-YCOHEN and keep the host powered on to facilitate memory and disk forensics.

- Complete password resets for admin_dana, svc_backup, and y.cohen, and revoke all active Kerberos tickets or sessions.
- Purge the phishing email (Invoice_48213.docm) from all mailboxes across the organization.
- Inspect DC01 and FS01 for any secondary persistence mechanisms or unauthorized account creations.

Longer-Term Security Enhancements:

- Implement Attack Surface Reduction (ASR) rules to prevent Microsoft Office applications from creating child processes (e.g., PowerShell or CMD).
- Enable Defender Tamper Protection to prevent local registry changes from disabling antivirus components.
- Enforce Credential Guard and LSA Protection on all employee workstations to mitigate LSASS dumping.
- Restrict RDP access to Domain Controllers strictly to Dedicated Admin Workstations.
- Configure alerts for service accounts (e.g., svc_sql, svc_backup) executing interactive sessions or operating outside designated hosts.
- Deploy DNS tunneling detection algorithms and restrict outbound uploads to uncategorized cloud storage platforms.
- Conduct targeted phishing awareness training for the Finance department focused on macro-enabled attachment risks.

11. Severity rationale

Critical. The incident warrants a Critical severity rating due to the following compounding factors:

Privilege & Domain Compromise: The attacker successfully stole a Domain Administrator credential (admin_dana) and used it to establish an unauthorized RDP session to the primary domain controller (DC01), alongside compromising the svc_sql service account, leaving high uncertainty regarding the full extent of compromised credentials.

Data Theft & Exfiltration: The attacker executed a bulk read of 412 sensitive files from the Finance share on FS01 and subsequently exfiltrated 1.4 GB of data to an external, unsanctioned cloud-storage platform (filebin-share[.]net).

Destructive Intent / Recovery Impact: The attacker attempted to disable local system recovery by executing shadow copy deletion commands on the backup server (BKP01), significantly escalating the threat profile toward potential ransomware deployment.